

Business Associate Agreement

Last updated: September 2026.

1. Parties

This Business Associate Agreement ("Agreement") is entered into between the covered entity identified at account registration ("Covered Entity") and Cardio AI Corp, operator of CardioAI Pro ("Business Associate").

2. Definitions

Terms used but not otherwise defined in this Agreement have the meanings assigned in the HIPAA Privacy, Security, and Breach Notification Rules, including "Protected Health Information" (PHI), "Electronic PHI" (ePHI), "Required by Law," "Secretary," and "Subcontractor."

3. Permitted Uses and Disclosures of PHI

Business Associate may use or disclose PHI only as necessary to perform the services described in the underlying service agreement with Covered Entity, or as Required by Law. Business Associate may not use or disclose PHI in a manner that would violate the Privacy Rule if done by Covered Entity, except as permitted for Business Associate's own proper management and administration.

4. Safeguards

Business Associate will implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of ePHI, consistent with the HIPAA Security Rule. Technical safeguards currently implemented in this system include: role-based access control enforced server-side, hashed password storage, signed session tokens delivered via httpOnly cookies, and encrypted connections. **Not yet implemented, and required before this section can be honestly represented as satisfied: audit logging of PHI access at the record level, encryption-at-rest verification for all storage backends in**

active use, and a documented risk assessment.

5. Reporting of Breaches and Security Incidents

Business Associate will report to Covered Entity any use or disclosure of PHI not permitted by this Agreement, including breaches of unsecured PHI, without unreasonable delay and in no case later than the timeframe required by the Breach Notification Rule.

6. Subcontractors

Business Associate will ensure that any subcontractor that creates, receives, maintains, or transmits PHI on its behalf agrees to the same restrictions and conditions that apply to Business Associate under this Agreement, including Render (application hosting) and Cloudflare (document storage).

7. Access, Amendment, and Accounting

Business Associate will make PHI available to Covered Entity as necessary to satisfy Covered Entity's obligations to provide individuals with access to, amendment of, and an accounting of disclosures of their PHI under the Privacy Rule.

8. Minimum Necessary

Business Associate will request, use, and disclose only the minimum necessary PHI to accomplish the intended purpose.

9. Term and Termination

This Agreement is effective as of the date of execution and terminates upon termination of the underlying service agreement. Upon termination, Business Associate will return or destroy all PHI received from Covered Entity, or, if not feasible, extend the protections of this Agreement to the PHI retained.

10. Miscellaneous

This Agreement will be interpreted to comply with HIPAA. In the event of a conflict between this Agreement and the underlying service agreement regarding PHI, this Agreement controls.

11. Contact

Questions about this Agreement: invest@cardioalive.com